

QA LAB BRASIL

Reference guide - QA Lab Brasil

Authentication and Authorization

Login, sessions, cookies, tokens, JWT, OAuth, OIDC, SSO, MFA and access control.

Authentication vs Authorization

Authentication answers who the user is. Authorization defines what that user may do. An authenticated user reaching an admin function without permission is an authorization failure.

Sessions and tokens

Applications may use session cookies or tokens. JWT is a token format; OAuth 2.0 is an authorization framework; OpenID Connect adds an identity layer on top of OAuth 2.0.

SSO and MFA

Single Sign-On lets an identity be reused across applications. Multi-Factor Authentication requires additional factors and should be tested for success, failure, recovery and expiration.

QA scenarios

Validate invalid credentials, logout, expiration, role-based access, user switching, protected URLs, concurrent sessions and error messages without unnecessary disclosure.

QA Tip: A working login does not prove authorization is correct: always test roles and protected resources.

Official: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html